

# Sécuriser les systèmes

Quelques pistes



# Plan

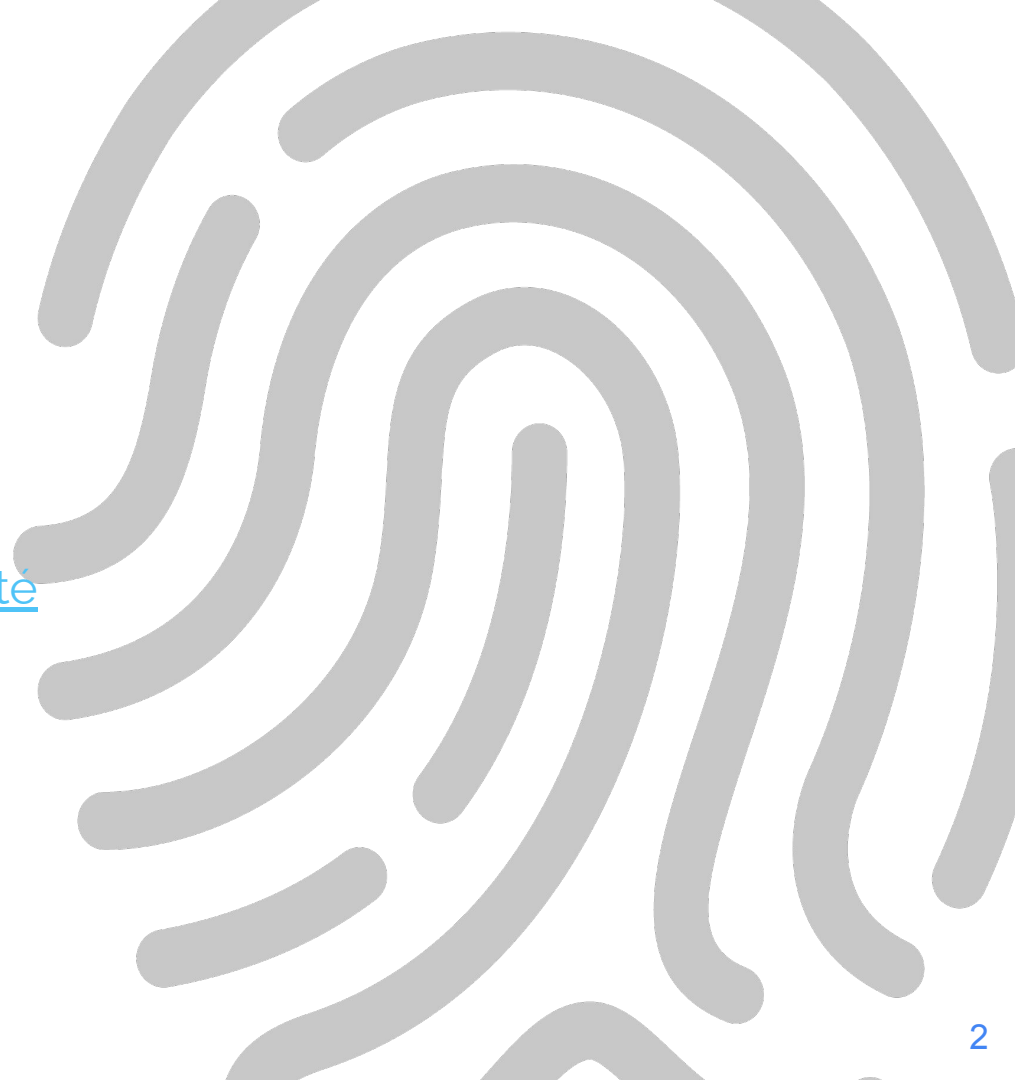
[1 - Introduction](#)

[2 - Sécurité physique](#)

[3 - Les logiciels](#)

[4 - Droits d'accès](#)

[5 - Composants et outils de sécurité](#)





# Introduction



# Sécuriser ses systèmes

Objectif de l'administrateur système :

- Fournir des serveurs (et terminaux clients) pour supporter les applicatifs métier
- Les maintenir en condition opérationnelle

Les incidents de sécurité nuisent à cette mission

=> Sécuriser ses systèmes



# Objectifs

- Un serveur (ou un poste de travail) est un environnement complexe avec de nombreux composants
- Chacun de ces composants comporte potentiellement une vulnérabilité

Réduire la surface d'attaque (Principe de minimisation) :

- Réduire le nombre de composants au strict minimum pour
  - Permettre des mises à jour et un suivi efficace (prévenir)
  - Simplifier la surveillance (détecter)



# Le compromis

Mesure de sécurité vs Confort d'utilisation

Chaque élément du SI est présent, en principe, pour assurer une fonction

- En général, en interaction avec des utilisateurs

Les mesures de sécurité ne doivent pas empêcher l'utilisation légitime du SI.

- Sensibilisation et formation des utilisateurs



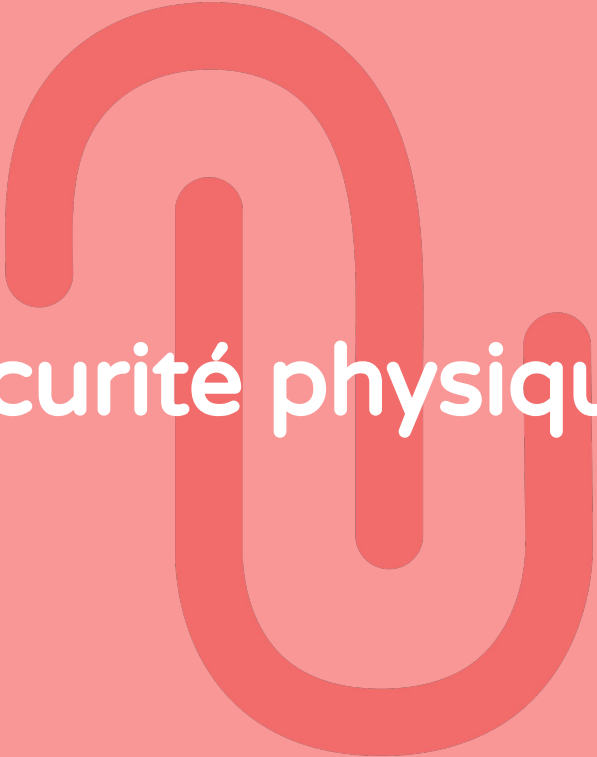
# Défense en profondeur

Le filtrage au niveau du réseau est complémentaire

En principe, seul le trafic vers les services ouverts est possible depuis l'extérieur, mais...

- Les services ouverts peuvent être vulnérables
- L'attaquant pourrait être interne (ou via rebond)

Recommandation : mettre autant de barrières que possible pour retarder/dissuader un attaquant



# Sécurité physique





# La sécurité physique

Un système sécurisé est enfermé dans une armoire à clé...

- Parfois, c'est le cas : machine autorité de certification

En général : restreindre autant que possible l'accès physique aux machines

Sinon (ou en plus) :

- Mot de passe de démarrage (BIOS et/ou boot)
- Démarrage via périphériques amovibles désactivé
- Chiffrement des disques



# Minimisation physique

Disposer uniquement du nécessaire

- Périphériques d'entrée (port USB, lecteur optique...)
- Périphériques réseaux (ethernet, wifi, bluetooth)
  - Possibilité de désactivation matérielle et activation au besoin
- Composant d'administration à distance



## Choix du matériel

Choisir du matériel de confiance...

- Fournisseur de confiance (?)
- Conformité précise du matériel fourni aux spécifications (rien de plus)
- Engagement de maintenance dans le temps

Présence d'un support matériel pour des fonctions de sécurité

- Virtualisation des I/O (VT-x ou AMD-v)
- *Trusted Platform Module* (TPM) - Stockage sécurisé de clés cryptographiques

[Open Hardware](#)



# Les logiciels



## Inventaire

Systèmes d'exploitation

- Très nombreux composants
- Installés par défaut - Proposés à l'installation
- Recommandation : désinstaller les composants/services inutiles

Applications supplémentaires

- Dépendances (bibliothèques...)

Firmware - logiciels intégrés aux matériels

Suivi de l'inventaire => Outil de gestion de parc



# Choix et récupération

Éditeur de confiance (?)

- Assure les correctifs sur le long terme

Auditable (*Open Source*) voir audité (labels)

Support d'installation non compromis

- Récupération uniquement via les sites *officiels*
- Vérification lors des téléchargements (empreintes, signatures numériques)

Recommandation : utiliser un [gestionnaire de paquets](#) avec dépôts



# Configuration

La configuration d'un système est importante

- La configuration par défaut pas forcément satisfaisante
  - Ex : mot de passe par défaut

Appliquer les recommandations de l'éditeur (ou tierce)

Quelques exemples :

- Services en écoute spécifiquement sur l'interface d'accès



# Découverte de vulnérabilité

Même les meilleurs logiciels ne sont pas parfaits et en général, ils évoluent :

- nouvelles fonctionnalités => nouvelles failles potentielles...

Les spécialistes de la cybersécurité (chercheurs, [SOC](#), auditeurs...) peuvent trouver de nouvelles vulnérabilités ([o-day](#))

Démarche habituelle :

- Éditeur prévenu (faille encore confidentielle)
- Développement d'une mise à jour
- Publication du correctif et de la [CVE](#) (gestion par [MITRE](#))





# Exploitation de vulnérabilité

Exploiter une vulnérabilité o-day est souvent complexe

Les vulnérabilités publiées entrent dans les boîtes à outils d'audit et de test d'intrusion

=> Automatisation de l'exploitation

Il devient alors beaucoup plus facile d'exploiter ces failles

- Nouvelle catégorie de menace : [Script kiddies](#)



## Mise à jour

La **mise à jour** de **tous** les logiciels **au plus vite** est donc essentielle !

Mais...

L'application de la mise à jour change (plus ou moins) le logiciel

=> Risque pour la production

Gestion des mises à jour avec des tests et des environnements dédiés

=> Nécessité méthodologique



# La gestion des versions

Les **évolutions** d'un logiciel sont en général indiquée via **numéros de version**

La **gestion sémantique** de version ([Semver](#)) est courante

- Format : <N°Majeur>.<N°Mineur>.<N°Patch>
- **Majeur** : Changements non rétro-compatibles
- **Mineur** : Ajout de fonctionnalités rétro-compatibles
- **Correctif** (*Patch*) : Correctifs rétro-compatibles

Chaque version majeure peut-être maintenue séparément

LTS ([Long Term Support](#)) : Version maintenue sur une longue période

Mais arrive forcément un moment où une version n'est plus maintenue



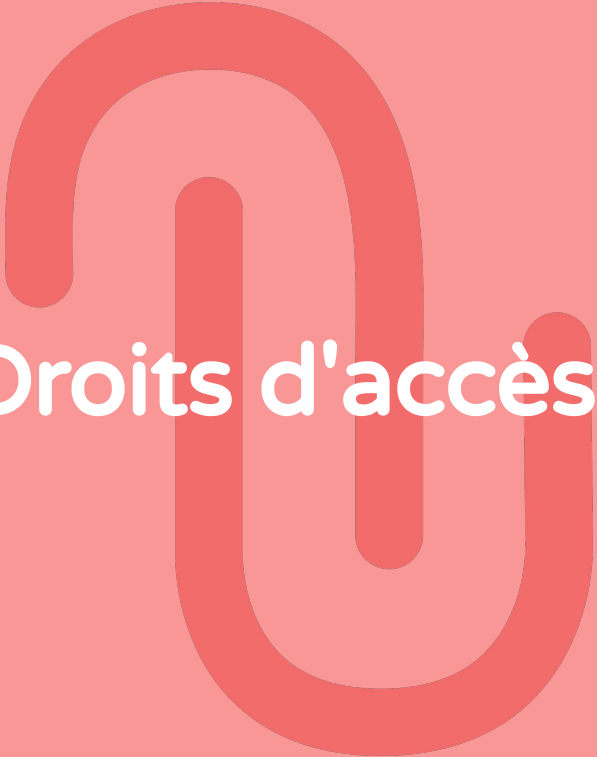
# Obsolescence

Les versions non maintenues doivent être migrées

- Projet - Tests et validation

Les systèmes qui ne sont pas migrés sont dit hérités ([legacy](#))

- Ils demandent une attention particulière
- Meilleur cloisonnement



# Droits d'accès



# Les droits d'accès

Les logiciels disposent, en général, d'une gestion des droits d'accès :

- Propre et/ou centralisée
- Basé sur de l'authentification
- Association de droits plus ou moins fins



# L'authentification

Quelques recommandations sur l'authentification

- Utiliser/imposer des mots de passes robustes
- Authentification à facteurs multiples ([MFA](#) ou 2FA)
- [Authentification forte](#) (cryptographique)



# Gestion des utilisateurs

- Désactiver/supprimer les comptes inutiles (ou plus utiles)
- Interdire les comptes partagés (Invité, Stagiaire...)
- Appliquer les principes de moindre privilège
  - Les besoins particuliers => comptes particuliers
  - Administrateurs = plusieurs comptes
  - Utiliser des mécanismes d'élévation temporaire de privilèges (sudo)
- Adopter une procédure d'arrivée et de départ (création/destruction)





# Composants et outils de sécurité



## Des outils de sécurité

Sécuriser un système :

- Complexe : énormément de points à prendre en compte
- Nécessite de l'automatisation : vérification manuelle exhaustive impossible

Logiciels de sécurité

- Antivirus
- HIDS et HIPS (Host-based Intrusion Detection/Prevention System)
- EDR ([Endpoint Detection and Response](#))
- Firewall personnel



## Antivirus

Recherche de logiciels malveillants

- Base de signatures
- Comportements suspects
- [Analyse heuristique](#)

Recommandation :

- Déployer sur les serveurs et les clients (tout système)

Un antivirus libre : [ClamAV](#)

Plus d'info : [antivirus](#) (sur wikipedia )



## HIDS

Détecteur d'attaque sur base

- Activité de la machine (CPU, mémoire, réseau, etc...)
- Modification sur le système de fichier
- Journaux d'événements...

Détection/Prévention = alerte/action automatique

- [Samhain](#)
- [OSSEC](#)
- [fail2ban](#)
- [crowdsec](#)

Plus d'info : [hids](#) (sur wikipedia )



# Conclusion

- Quelques éléments et recommandation de sécurisation des systèmes
- Principe de minimisation, de moindre privilège
- Outils de sécurité



**Et vous, quelles sont vos astuces ?**



# Bibliographie

## Guides ANSSI :

- [Cybersécurité des systèmes d'information](#)
- [Recommandations de configuration d'un système GNU/Linux](#)
- [Mettre en oeuvre une politique de restriction logicielle sous Windows](#)
- [Restreindre la collecte des données sous Windows 10](#)

## Source d'info sur les vulnérabilités :

- [CVE](#)
- [CERT-FR](#)
- [MITRE ATT&CK](#)